Pergunta 1: __/__/____

Não podemos usar o método String.Equals() para comparar senhas porque as senhas não devem ser armazenadas em texto puro no sistema. Quando utilizamos o BCrypt, a senha é transformada em um hash seguro, que não pode ser revertido facilmente para a senha original. Assim, no momento do login, não comparamos as senhas diretamente, mas sim usamos o BCrypt.checkPW(), que verifica se a senha digitada corresponde ao hash armazenado. Isso aumenta a segurança e protege os usuários em caso de vazamento de dados.

skypaper

__/__/____

Pergunta 2:

A Secret_Key é essencial para garantir a autenticidade do token JWT. Se um atacante tiver acesso a essa chave, ele poderá gerar tokens válidos, como se fosse um usuário legítimo do sistema. Isso compromete totalmente a segurança, pois o atacante poderia acessar rotas protegidas, se passar por outros usuários e até obter privilégios indevidos. Por isso, essa chave deve ser mantida em segredo e armazenada em variáveis de ambiente

ypaper

__/__/____

Pergunta 3:

O ataque de enumeração de usuários acontece quando um sistema informa ao atacante se um usuário existe ou não, por meio de mensagens diferentes no login. Por exemplo, dizer "usuário não encontrado" ou "senha incorreta" separadamente facilita esse tipo de ataque. Na nossa implementação, utilizamos mensagens genéricas como "email ou senha inválidos", sem indicar qual dos dois que está incorreto. Desse modo, dificultamos que um atacante descubra quais usuários estão cadastrados no sistema.

skypaper

__/__/____

Pergunta 4:

A codificação em Base64 serve apenas para transformar os dados em um formato que possa ser transmitido facilmente, mas não oferece segurança, pois qualquer pessoa pode decodificar. Já a assinatura (HMAC) garante a integridade do token, ou seja, assegura que ele não foi alterado, utilizando a Secret_Key. É perigoso armazenar a senha no payload do JWT porque, como ele é apenas codificado em Base64, qualquer um poderia decodificar e ver essas informações sensíveis, comprometendo a segurança do usuário

skypaper

__/__/____

Pergunta 5

O armazenamento do token apenas em memória (11Fe) foi feito para evitar ataques como o XSS (Cross-Site Scripting). Se o token fosse salvo no localStorage, um script malicioso poderia acessá-lo facilmente e roubar a sessão do usuário. Ao manter o token apenas em memória, ele não fica persistido no navegador, reduzindo o risco de exposição em caso de ataque.

skypaper